MANDALUYONG COLLEGE OF SCIENCE AND TECHNOLOGY
Bachelor of Science in Information Systems

INFORMATION TECHNOLOGY AUDIT REPORT

N-VISION

Professional Audit Report - Increment 3

Lab 9: Risk and Compliance Assessment

Audit Team / Group No.	N-VISION Audit Team | [Group number - confirm]
Capstone System / Build	N-VISION: A Data-Driven Ticketing System for Optimized Anti-Rabies Vaccination Management | v1.0 | pilot deployment, Mandaluyong City ABTC (as stated in Lab 8; see REC-09-08)
Partner Organization	Mandaluyong City Animal Bite Treatment Center (ABTC) / Mandaluyong City Health Office, Mandaluyong City LGU
Member 1 / Role	Edmar A. Isidro | Risk Assessment Lead
Member 2 / Role	Celso L. Daclis | Compliance and Privacy Analyst
Member 3 / Role	Alvin T. Tinaan | Technical Risk and Evidence Analyst
Prior Approved Version	Lab 8 report version 0.2 / [approval date]
Current Version / Date	Version 0.3 | [preparation date] | [submission date]
Audit / Evidence Cutoff	[Confirm date and time] - evidence basis carried from Lab 8 (N-VISION capstone paper and pilot/UAT records); no new evidence was added in this increment

Master-report instruction
Use these pages to add the Lab 9 increment to the existing professional audit report. Apply prior instructor corrections, update the master version history and build register, preserve approved IDs, and submit the complete updated master unless the instructor directs otherwise.

A. Master Report Update Control

A.1 Version History Entry

Version	Date	Lab / Increment	Prepared By	Reviewed By	Change Summary
0.3	[Date]	Lab 9 / Increment 3	Isidro, Daclis, Tinaan	[Reviewers - after cross-review]	Added Risk Register and Compliance Mapping and incorporated prior feedback

A.2 Final Audit Report Build Register Update

Lab	Report Section	Status	Version / Date	Instructor Action
7	Engagement Profile and Scope	Completed	0.1 / [Lab 7 date]	Approved (per Lab 8 register; confirm)
8	Asset Inventory and System Documentation	Completed	0.2 / [date]	[Approved / Revise / Pending]
9	Risk and Compliance Assessment	In Progress	0.3 / [date]	[Approved / Revise / Pending]
10	Control Assessment and Gap Analysis	Reserved		[Approved / Revise / Pending]
11	Audit Findings and Recommendations	Reserved		[Approved / Revise / Pending]
12	AI Validation Portfolio and Final Report Integration	Reserved		[Approved / Revise / Pending]

A.3 Prior Feedback Closure

Feedback ID	Prior Instructor Comment / Required Revision	Action Taken	Section / IDs Affected	Closed By / Date
FB-08-01	Keep the audit scope limited to the anti-rabies vaccination workflow at the ABTC rather than all City Health Office services.	Risk scenarios limited to MOD-01 to MOD-06 and the ABTC assets/accounts in the Lab 8 registers; no risks raised for other CHO services or general LGU infrastructure.	Section 1.2; MOD-01 to MOD-06; AST-01 to AST-10	[Member / date]
FB-08-02	Make trust boundaries between the LGU-managed server and third-party services explicit.	SMS gateway, cloud database provider, and DOH portal treated as external; third-party risks and obligations kept separate from internal ones.	RSK-05, RSK-06, RSK-07; CMP-07, CMP-11; DEP-04, DEP-05, DEP-07; INT-01 to INT-03	[Member / date]
FB-08-03	Separate documented facts from assumptions about provider-internal controls.	Provider-side and design-only safeguards are not used to reduce residual risk; residual is Not Determined or equal to inherent; assumptions are labelled in the Evidence / Assumption column.	RSK-01 to RSK-13 (residual columns); CMP-05 to CMP-08; LIM-01, LIM-02	[Member / date]
FB-08-04	Do not treat the partial-offline design as an already-tested control.	FLOW-06 / INT-07 offline mode is recorded as a design mitigation only; RSK-09 residual is Not Determined and conflict-resolution testing is a planned action.	RSK-09; FLOW-06; INT-07; EVD-08-01	[Member / date]

I. Risk and Compliance Assessment

1.1 Risk Scoring Method

Likelihood Scale	1 Rare - very unlikely under observed conditions | 2 Unlikely - possible but not expected during the pilot | 3 Possible - could reasonably occur; a relevant weakness exists and no evidenced safeguard fully addresses it | 4 Likely - expected under current conditions or has occurred | 5 Almost Certain - expected repeatedly; conditions strongly favor occurrence. Tailored to a small ABTC clinic using a LGU-managed on-premises server with internet-dependent integrations.

Impact Scale	1 Insignificant - no meaningful effect | 2 Minor - limited disruption corrected by staff the same day, no patient effect | 3 Moderate - noticeable operational, privacy, data, or service effect (e.g., delayed follow-up, limited record exposure) | 4 Major - patient dose schedule disrupted, identifiable patient health data exposed to unauthorized persons, or reports materially wrong | 5 Severe - patients may miss or receive incorrect post-exposure prophylaxis, large-scale exposure of sensitive health records, prolonged intake outage, or significant compliance/reputational effect on the LGU. Considers CIA, privacy, operations, compliance, finance, and reputation; patient safety and health-data sensitivity drive scores of 4-5.
Risk Formula	Risk Score = Likelihood x Impact (range 1-25)
Risk Bands	1-4 Low | 5-9 Moderate | 10-16 High | 17-25 Critical. Applied to inherent, residual, and expected-residual scores in every section of this report.
Residual Risk Basis	Inherent risk is scored before safeguards. Residual risk is reduced only when a safeguard exists in the audited build or process AND is supported by an EVD record. Three outcomes are used: (a) safeguard evidenced - likelihood and/or impact reduced with a written reason; (b) no safeguard evidenced - residual equals inherent; (c) safeguard only described (design documents, self-reported UAT/survey, provider statements) - residual is Not Determined and no reduction is applied. Planned or partial features (e.g., AST-10 cloud sync) never reduce residual risk.
Risk Acceptance Authority	ABTC Officer-in-Charge / system owner (ORG-01) for ABTC-level risks; City Health Office management for risks above ABTC level. The student team does not approve organization risk; no risk in this report is marked Accepted.

1.2 Risk Register

Band key: 1-4 Low | 5-9 Moderate | 10-16 High | 17-25 Critical. Scores are shown as Likelihood / Impact / Score. ID sources: Lab 8 registers (AST, ACC, INT, DEP, FLOW, EVD, USR, ORG, MOD).

RSK ID	Risk Scenario	Affected IDs	Evidence / Assumption	Inherent L/I/Score	Existing Safeguards	Residual L/I/Score	Owner	Treatment / Priority
RSK-01	Because the IT support / system administrator account (ACC-04) holds broad privileges (user and role management, configuration, database maintenance, deployment) and segregation-of-duties and logging evidence is limited, administrative changes to accounts, settings, or patient and vaccination records may not be reviewed or attributable to a specific person, resulting in weak accountability and possible unauthorized or undetected changes to patient care records.	ACC-04; USR-06; ORG-03; AST-02, AST-03, AST-04, AST-05, AST-06; FLOW-01 to FLOW-03; EVD-08-01	EVD-08-01 (ACC-04: SoD evidence limited; logging extent not fully verified). L3: privileged access held by the capstone team and not reviewed. I5: changes could alter dose records.	3/5/15 (High)	Named privileged account; admin changes logged, extent not verified (ACC-04).	Not Determined - logging described only; no reduction applied.	ABTC system owner (ORG-01); custodian ORG-03	Mitigate + H
RSK-02	Because staff access depends on username/password login (INT-05; ACC-01 to ACC-04) with no additional factor, lockout, or session-timeout evidence, stolen, guessed, or shared credentials on front-desk and clinic workstations may allow unauthorized access to patient bite-case, schedule, and inventory records, resulting in disclosure or alteration of sensitive personal information.	ACC-01 to ACC-04; USR-03 to USR-06; AST-01, AST-02, AST-04, AST-05; INT-05; DEP-02; FLOW-01, FLOW-02; EVD-08-04, EVD-08-05	INT-05 (role-based username/password login); EVD-08-04/05 (UAT and ISO 25010 survey, self-reported). Password policy, lockout, timeout not evidenced (assumption: not configured). L3: shared clinic workstations. I5: sensitive health data.	3/5/15 (High)	Named accounts, role-based access, login and clinical-action logging (ACC-01 to ACC-03) - documented, self-reported only.	Not Determined - no configuration evidence; no reduction.	ABTC system owner (ORG-01)	Mitigate + H
RSK-03	Because HTTPS for staff browser access is only "recommended" in the documented design (DEP-02) and no TLS configuration evidence exists, patient data and login credentials may be intercepted or altered on the clinic/LGU network, resulting in disclosure of health information and loss of record integrity.	DEP-01, DEP-02; INT-05; AST-01, AST-02; ACC-01 to ACC-03; FLOW-01, FLOW-02; EVD-08-04	DEP-02 wording ("HTTPS recommended"); no TLS evidence in EVD-08-01/02 (design-stage). Assumption: internal network is not fully trusted. L2: interception needs network access. I5: health data and credentials.	2/5/10 (High)	None evidenced for the staff-to-application link (HTTPS to SMS gateway and encrypted cloud sync are separate links).	2/5/10 - no safeguard evidenced; residual equals inherent.	ABTC system owner (ORG-01); server custodian ORG-02	Mitigate + H

RSK ID	Risk Scenario	Affected IDs	Evidence / Assumption	Inherent L/I/Score	Existing Safeguards	Residual L/I/Score	Owner	Treatment / Priority
RSK-04	Because accounts are deactivated on staff exit but periodic access/privilege review is not evidenced (ACC-01 to ACC-03), dormant or over-privileged accounts may retain access to patient records beyond the need of the role, resulting in unnecessary exposure of personal data and unauthorized changes.	ACC-01 to ACC-03; USR-03 to USR-05; ORG-01; AST-03 to AST-06, AST-09; MOD-01 to MOD-04, MOD-06; EVD-08-04, EVD-08-05	Lab 8 ACC-01 to ACC-03: review cadence not documented. L3: weakness exists, no review. I4: record exposure limited to current staff roles.	3/4/12 (High)	Deactivation on staff exit and role-based privileges (documented; operation not evidenced).	3/4/12 - deactivation-on-exit does not address privilege review and is itself unevidenced; residual equals inherent.	ABTC clinic head / access approver (ORG-01)	Mitigate + H
RSK-05	Because the application database account (ACC-05), SMS gateway API key (ACC-06), and cloud sync credential (ACC-07) have no evidenced rotation, revocation, or monitoring, a leaked connection string or key could allow unauthorized read/write of patient, schedule, and inventory data, misuse of the SMS channel, or access to the cloud copy, resulting in a data breach that bypasses application role controls and may be hard to detect.	ACC-05, ACC-06, ACC-07; AST-02, AST-03, AST-08, AST-10; INT-01, INT-02; DEP-04, DEP-05; EVD-08-01, EVD-08-02, EVD-08-06, EVD-08-07	Lab 8 ACC-05 to ACC-07: rotation/disable not evidenced; database-level logging not fully available; provider-side logs only. Assumption: credentials sit in application configuration on the LGU server. L3. I5.	3/5/15 (High)	Managed credentials; HTTPS API calls; encrypted sync connection (documented, not verified; AST-10 partial/planned).	Not Determined - no reduction.	Capstone team custodian (ORG-03) under system owner (ORG-01)	Mitigate + H
RSK-06	Because patient, schedule, inventory, and log records are synchronized to an external cloud database provider (INT-02, AST-10) whose internal controls and contractual obligations are not evidenced, patient health data may be accessed, retained, or lost outside ABTC/LGU control, resulting in privacy exposure and possible compliance issues over third-party processing.	AST-10, AST-03 to AST-06; INT-02, INT-07; DEP-05; ACC-07; FLOW-06; ORG-05; EVD-08-01, EVD-08-07	DEP-05 limitation and REC-08-02 / LIM-01: provider-side controls not evidenced; AST-10 status Partial/planned. Assumption: no provider agreement has been reviewed. L3. I5.	3/5/15 (High)	Encrypted sync connection and restricted credentials (documented; AST-10 partial/planned, so not counted).	Not Determined - provider controls unverified.	ABTC system owner (ORG-01); provider ORG-05	Mitigate + H
RSK-07	Because reminder messages and patient phone numbers are sent through an external SMS gateway (INT-01, AST-08) whose provider-side controls are not evidenced and which depends on internet connectivity, contact numbers or treatment-related message content may be exposed to the provider and reminders may be delayed or fail, resulting in privacy exposure and missed follow-up doses.	AST-08, AST-02; INT-01; DEP-04; ACC-06; FLOW-04; MOD-05; USR-01; ORG-04; EVD-08-01, EVD-08-06	EVD-08-06 (sprint-plan description, no delivery log); INT-01: no automatic voice fallback. Assumption: messages mention appointment/vaccination wording. Scope dependency: see REC-09-02. L3. I3.	3/3/9 (Moderate)	HTTPS API, API key, local delivery-status log (documented from sprint plan only).	Not Determined - no delivery log or provider evidence.	ABTC system owner (ORG-01); provider ORG-04	Mitigate + M
RSK-08	Because the local MySQL database on the LGU-managed server is the primary store, cloud backup (AST-10) is documented as partial/planned, and restoration has not been demonstrated, a server or database failure may cause loss or prolonged unavailability of patient and dose records, resulting in interrupted intake and missed or duplicated post-exposure doses.	AST-03 to AST-06, AST-10; INT-02, INT-05, INT-07; DEP-03, DEP-05; FLOW-01 to FLOW-03, FLOW-06; EVD-08-01, EVD-08-02	AST-10 status Partial/planned; INT-02: backup/restore unavailable during outage; no restore test or backup log. L3. I4: dose history loss disrupts treatment.	3/4/12 (High)	Local operation continues offline (design only, untested - FLOW-06); planned cloud sync and "manual/paper fallback" (INT-05) not evidenced.	3/4/12 - no operating backup/restore evidenced; planned features not counted.	LGU Health Office database custodian (ORG-02); ORG-01	Mitigate + H

RSK ID	Risk Scenario	Affected IDs	Evidence / Assumption	Inherent L/I/Score	Existing Safeguards	Residual L/I/Score	Owner	Treatment / Priority
RSK-09	Because registration and ticketing continue offline and are queued for synchronization (FLOW-06, INT-07) with conflict-resolution behavior untested, duplicate, overwritten, or missing patient and dose records may result after reconnection, leading to an incorrect patient history and dose schedule.	FLOW-06, FLOW-01; INT-07; AST-01, AST-03, AST-04, AST-10; MOD-01, MOD-02; EVD-08-01 (limitation)	REV-08-03 / FB-08-04: conflict resolution not independently tested. L2: needs connectivity loss plus concurrent edits. I4.	2/4/8 (Moderate)	Local validation, duplicate-patient search, offline queue (design only).	Not Determined - design-only; no reduction.	ABTC system owner (ORG-01); ORG-03	Mitigate + M
RSK-10	Because patient registration and PEP dose-schedule computation rely on application validation (FLOW-01, FLOW-02) that is described but not independently tested, incorrect or duplicate patient records or an incorrectly computed dose schedule may be saved, resulting in missed, delayed, or incorrect post-exposure doses and compromised patient safety.	FLOW-01, FLOW-02; AST-02, AST-04, AST-05, AST-07; MOD-01, MOD-03; ACC-01 to ACC-03; EVD-08-02, EVD-08-04	EVD-08-02 (narrative); EVD-08-04 (UAT, 8 respondents, self-developed). Assumption: clinicians would notice most errors (not evidenced). L2. I5: patient safety.	2/5/10 (High)	Required-field validation, duplicate-patient search, PEP schedule computation (documented).	Not Determined - not tested.	ABTC Officer-in-Charge / clinical lead (ORG-01)	Mitigate + H
RSK-11	Because automatic vaccine-stock deduction and low-stock alerting (FLOW-03) are described but not tested and historical log retention is not evidenced, recorded stock may differ from physical stock (e.g., wastage, returns, expiry), resulting in unexpected stock-outs, use of expired vaccine, and disrupted treatment.	FLOW-03; AST-06, AST-02; MOD-04; EVD-08-02, EVD-08-03	EVD-08-03 (functional description only, no tested data). Assumption: a physical stock reconciliation process exists at ABTC (not evidenced). L3. I4.	3/4/12 (High)	Automatic deduction and threshold alert (documented).	Not Determined - untested.	ABTC nurse/pharmacy custodian (ORG-01)	Mitigate + H
RSK-12	Because formal retention and disposal periods for patient, schedule, notification, and report records are not documented (REC-08-04, LIM-02) and copies also exist in the cloud database and report archive, records may be kept longer than necessary or deleted inconsistently, resulting in unnecessary privacy exposure and difficulty responding to record requests.	AST-04, AST-05, AST-06, AST-09, AST-10; FLOW-01 to FLOW-05; DEP-05; EVD-08-02	REC-08-04 exception; FLOW-01 cites a clinic retention policy that is not evidenced. L3. I3.	3/3/9 (Moderate)	Clinic record-retention policy referenced, not provided.	Not Determined - policy not provided.	ABTC system owner (ORG-01); ORG-02	Mitigate + M
RSK-13	Because deployment, configuration, and maintenance are performed by the capstone team acting as custodian and administrator (ACC-04, ORG-03) and no change-review or post-project support arrangement is evidenced, unreviewed changes or lapsed maintenance may introduce defects or vulnerabilities, resulting in service disruption or data exposure.	ACC-04; ORG-03; AST-01, AST-02, AST-03, AST-07, AST-10; EVD-08-01	Assumption (not stated in Lab 8): no change-approval process or long-term support arrangement is documented; confirm with ORG-01. L3. I3.	3/3/9 (Moderate)	None evidenced.	3/3/9 - no safeguard evidenced; residual equals inherent.	ABTC system owner (ORG-01)	Mitigate + M

II. Compliance, Privacy, and Requirements Mapping

2.1 Compliance Obligations Matrix

Statuses follow the Lab 9 labels. Not Determined means the reliable evidence needed to conclude was not available; it is not a finding of noncompliance. Exact clause wording is paraphrased and must be verified against the official text.

CMP ID	Source	Exact Requirement / Section	Why Applicable	Owner	Required Evidence	Current Status	Related RSK / CRT	Gap / Action
CMP-01	RA 10173 (Data Privacy Act of 2012), Sec. 13(f)	Processing of sensitive personal information, including health data, is allowed where necessary for medical treatment, carried out by a medical practitioner or treatment institution, and an adequate level of protection is ensured.	ABTC-IMS processes patient health and bite-incident data (AST-04, AST-05) for post-exposure treatment by a government health facility.	ABTC Officer-in-Charge (ORG-01)	Documented purpose/lawful-basis statement for health data; evidence of protection measures (CMP-05, CMP-06)	Not Determined	RSK-01, RSK-02, RSK-10; CRT: [confirm]	No lawful-basis record or collection text in the evidence set. Obtain the ABTC statement and confirm whether the pilot handles real patient data (Lab 7 authorizes demo/de-identified data only).
CMP-02	RA 10173, Sec. 11(a) and (d)	Personal data is collected for specified, legitimate purposes declared to the data subject, and is adequate and not excessive for those purposes.	Registration and reminder functions collect demographic, bite-incident, and contact-number data (FLOW-01, FLOW-04).	ABTC Officer-in-Charge (ORG-01)	Privacy notice / collection text at registration; field list mapped to purposes	Not Determined	RSK-07, RSK-12	Only the UAT instrument (EVD-08-04) is available; no notice or field inventory. Obtain registration form and notice.
CMP-03	RA 10173, Sec. 11(c)	Personal data is accurate, relevant, and kept up to date; inaccurate or incomplete data is rectified.	Dose schedules and patient histories drive treatment decisions (FLOW-01, FLOW-02, FLOW-06).	ABTC Officer-in-Charge (ORG-01)	Validation rules, test records of schedule computation and sync reconciliation	Not Determined	RSK-09, RSK-10	Validation is described (EVD-08-02) but untested. Plan reperformance in Lab 10.
CMP-04	RA 10173, Sec. 11(e) and (f); ABTC record-retention policy (referenced in FLOW-01)	Personal data is retained only as long as necessary for its purpose and kept identifiable no longer than necessary; clinic policy sets the retention period.	Patient, schedule, notification, and report records are stored locally and in cloud/archive copies (FLOW-01 to FLOW-05).	ABTC Officer-in-Charge (ORG-01); LGU Health Office (ORG-02)	Approved retention schedule; archive/delete function or procedure	Not Determined	RSK-12	Clinic policy not provided and REC-08-04 shows no period documented. Obtain policy; define disposal for cloud copies.
CMP-05	RA 10173, Sec. 20(a)-(c); IRR Rule VI, Secs. 25 and 28 (technical security measures: access control, authentication, encryption in storage and transit)	Reasonable and appropriate security measures protect personal data against unlawful access, alteration, and loss, taking into account data sensitivity and risk.	Sensitive health data is stored in MySQL (AST-03) and transmitted to staff browsers, an SMS gateway, and a cloud provider.	System owner (ORG-01); server custodian (ORG-02); capstone team (ORG-03)	Role matrix, authentication settings, TLS configuration, encryption statements, access logs	Partial	RSK-01 to RSK-05; CRT: least-privilege criterion [confirm ID]	Design documents show named role-based accounts, HTTPS to SMS API, encrypted sync. Gaps: staff HTTPS only recommended (DEP-02), no storage-encryption or configuration evidence, effectiveness untested. Status rests on design-level evidence only.
CMP-06	IRR Rule VI, Sec. 28 (ability to restore availability and access to personal data; process for regularly testing security measures)	The organization can restore availability and access to personal data in a timely manner after a physical or technical incident and regularly tests its measures.	A single LGU-managed server is the primary store; cloud backup is partial/planned (AST-10).	LGU Health Office (ORG-02); ORG-01	Backup schedule/log, restore test record, downtime procedure	Not Determined	RSK-08, RSK-09	No backup log or restore test; AST-10 is partial/planned. Obtain evidence or record limitation.

CMP ID	Source	Exact Requirement / Section	Why Applicable	Owner	Required Evidence	Current Status	Related RSK / CRT	Gap / Action
CMP-07	RA 10173, Sec. 14 (subcontracting of personal information processing)	A controller that subcontracts processing remains responsible for ensuring safeguards and that the processor complies with the Act.	Cloud provider (ORG-05) stores patient records; SMS provider (ORG-04) receives contact numbers.	ABTC Officer-in-Charge (ORG-01); LGU legal/DPO	Executed agreement or processing terms; provider security statement	Not Determined	RSK-05, RSK-06, RSK-07	LIM-01: provider-side controls and agreements not evidenced. Request in the next increment.
CMP-08	RA 10173, Sec. 20(f); IRR Rule IX (breach notification)	Defined process to detect and notify the National Privacy Commission and affected data subjects of qualifying breaches involving sensitive personal information.	System holds sensitive health data with limited logging (ACC-04, ACC-05).	LGU Health Office / City Health Office management (ORG-02)	Incident response and breach notification procedure, escalation contacts, sample log	Not Determined	RSK-01, RSK-05, RSK-06	No incident procedure in evidence. Obtain LGU/ABTC procedure and DPO contact.
CMP-09	RA 10173, Sec. 16 (rights of the data subject)	Patients can exercise rights such as access and correction through an approved process.	Patients are data subjects of AST-04 and AST-05; no portal function is documented in Lab 8.	ABTC Officer-in-Charge (ORG-01)	Request procedure/form; staff workflow for access and correction	Not Determined	RSK-09, RSK-10, RSK-12	No process evidence. Confirm whether handled manually at ABTC.
CMP-10	IRR Rule VI, Sec. 26 (organizational security measures, including a designated data protection officer)	A data protection officer is designated and policies exist for handling personal data.	ABTC operates under the City Health Office; accountability for health data spans ABTC and LGU roles.	LGU Health Office (ORG-02)	DPO designation record, data protection policy	Not Determined	RSK-04, RSK-05	No designation evidence in Lab 8. The Lab 7 workbook mentions a CHO privacy role (unverified).
CMP-11	DOH / partner reporting requirement for periodic vaccination and inventory reports (source document not provided)	[Exact clause to be obtained from the partner or DOH guidelines]	AST-09 compiles monthly reports submitted to the DOH portal (FLOW-05, INT-03).	ABTC Officer-in-Charge (ORG-01)	DOH reporting guideline/template, sample report, submission acknowledgement	Not Determined	RSK-11; CRT: [confirm]	Requirement not identified. Obtain source and confirm report scope (see REC-09-02).
CMP-12	Payment/financial-handling requirements	N/A	Not Applicable - none of the six Lab 8 modules (MOD-01 to MOD-06) process fees or payments; the Lab 7 workbook also lists billing as excluded.	N/A	N/A	N/A	-	Revisit only if a payment function is added.

2.2 Privacy Protection Assessment

Lab 8 defines no separate DATA IDs; the data-record assets AST-04 to AST-06 and AST-09 are used as the applicable data.

Privacy Area	Applicable DATA / FLOW	Expected Practice / Criterion	Evidence	Status	Risk / Required Action
Transparency / purpose	AST-04, AST-05; FLOW-01, FLOW-04	Patients are told why bite-incident, health, and contact data are collected, and data is used only for treatment, scheduling, reminders, and reporting.	EVD-08-04 (UAT only); no notice or collection text provided	Not Determined	CMP-01, CMP-02. Obtain registration form and privacy notice.
Data minimization	AST-04; FLOW-01, FLOW-04	Only fields necessary for registration, treatment, and reminders are collected.	EVD-08-02 (schema narrative; no field list)	Not Determined	CMP-02. Obtain sanitized field list and map to purposes.

Privacy Area	Applicable DATA / FLOW	Expected Practice / Criterion	Evidence	Status	Risk / Required Action
Access	AST-03 to AST-06, AST-09; FLOW-01 to FLOW-03, FLOW-05; ACC-01 to ACC-03	Personal records are limited to roles with a legitimate need and access is reviewed periodically.	EVD-08-04, EVD-08-05 (self-reported); review not evidenced	Partial	RSK-02, RSK-04. Obtain role matrix and periodic review record.
Security	AST-03, AST-10; FLOW-04 to FLOW-06; INT-01, INT-02; DEP-02	Sensitive records are protected in storage, access, transmission, backup, and export (authentication, encryption, access rules).	EVD-08-01, EVD-08-02, EVD-08-07 (design descriptions); no configuration or TLS evidence	Partial	RSK-01, RSK-03, RSK-05, RSK-06; CMP-05.
Retention	AST-04 to AST-06, AST-09, AST-10; FLOW-01 to FLOW-05	Defined reason and period for keeping records, with an archive/delete method including cloud copies.	REC-08-04 exception; clinic policy not provided	Not Determined	RSK-12; CMP-04.
Disclosure / sharing	AST-08, AST-09; FLOW-04, FLOW-05; INT-01, INT-03, INT-04, INT-06	Exports, reports, and messages are limited to authorized roles and recipients; public display shows no sensitive data (INT-06 states ticket number and status only).	EVD-08-06, EVD-08-07 (descriptions); ACC-03 may generate reports; DOH portal controls not evidenced	Not Determined	RSK-06, RSK-07; CMP-07, CMP-11. Obtain sample report and message template.
Data subject rights	AST-04, AST-05; FLOW-01, FLOW-02	Patients can request access or correction through an approved process.	None provided; no portal function in Lab 8	Not Determined	CMP-09; RSK-09, RSK-10.
Incident handling	AST-02, AST-03; ACC-01 to ACC-05	Incidents are detected, escalated, documented, and responded to; logs are available.	Logging described in Lab 8 (extent not verified); no incident procedure	Not Determined	RSK-01, RSK-05; CMP-08. Obtain incident procedure and sample log.

III. Risk Treatment and Audit Priority

RSK ID	Treatment	Proposed Action	Action Owner	Target / Trigger	Expected Residual Risk	Audit Test Priority	Rationale
RSK-01	Mitigate	Document separation between access approval and administration; enforce individual admin accounts; enable and retain admin/configuration/data-change logs; system owner reviews admin activity on a schedule.	ORG-01 (owner); ORG-03 (implement)	Before use with real patient data; monthly review	2/5 = 10 (High)	H	Impact stays Severe because admin misuse could alter dose records; segregation and logging reduce likelihood. High priority: evidence is limited and access is a critical objective.
RSK-02	Mitigate	Enforce password complexity, lockout, and session timeout; prohibit shared logins; assess a second factor for admin and doctor accounts; keep configuration evidence.	ORG-01; ORG-03	Before use with real patient data; test in Lab 10	2/5 = 10 (High)	H	Stronger authentication lowers likelihood but not impact. No configuration evidence exists yet.
RSK-03	Mitigate	Require HTTPS/TLS for all staff access, redirect plain HTTP, and keep sanitized TLS configuration evidence.	ORG-02; ORG-03	Before use with real patient data	1/5 = 5 (Moderate)	H	Simple, testable control; priority High because no evidence exists and data is sensitive.
RSK-04	Mitigate	Adopt periodic user-access review signed by the system owner (proposed quarterly), remove dormant accounts, and keep the role matrix current.	ORG-01 (clinic head)	First review shortly after pilot start; then quarterly	2/4 = 8 (Moderate)	H	Directly tests least-privilege access; no review evidence.

RSK ID	Treatment	Proposed Action	Action Owner	Target / Trigger	Expected Residual Risk	Audit Test Priority	Rationale
RSK-05	Mitigate	Document where credentials are stored; use a least-privilege database account; rotate database, SMS, and sync credentials on schedule and on staff change; enable database-level logging where feasible.	ORG-03; ORG-02	Before use with real patient data; on staff change or suspected exposure	2/5 = 10 (High)	H	Compromise would bypass application controls; practice not evidenced.
RSK-06	Mitigate (with Transfer/Share elements)	Obtain provider agreement and security statement; document which data is synchronized and minimize it; confirm data location and retention; decide whether AST-10 is enabled before real data is used.	ORG-01 with LGU legal/DPO	Before AST-10 holds real patient data	2/5 = 10 (High)	H	Provider controls are unverified; a contract shares duties but the ABTC remains responsible for patient data.
RSK-07	Mitigate	Confirm scope status of the SMS function (REC-09-02); keep message content free of diagnosis details; obtain provider terms; document a manual follow-up method for failed reminders.	ORG-01	Before SMS is used with real contact numbers	2/3 = 6 (Moderate)	M	Moderate exposure; scope status must be confirmed first.
RSK-08	Mitigate	Schedule backups of the local database with an offsite copy, perform and record a restore test, and document a manual/paper downtime procedure.	ORG-02; ORG-01	Before use with real patient data; restore test at least twice a year	2/4 = 8 (Moderate)	H	Loss of dose history disrupts treatment; no restore evidence.
RSK-09	Mitigate	Test offline-to-online sync with conflicting edits using demo data; define a conflict-resolution rule and a reconciliation report for staff.	ORG-03; ORG-01	Before offline mode is relied on; re-test after changes	1/4 = 4 (Low)	M	Design mitigation is untested (FB-08-04); testing is straightforward with demo data.
RSK-10	Mitigate	Reperform PEP schedule computation for each exposure category against the ABTC-approved regimen; test duplicate-patient and required-field validation; require clinician confirmation of generated schedules.	ORG-01 (clinical lead); ORG-03	Before use with real patient data; test in Lab 10	1/5 = 5 (Moderate)	H	Patient-safety impact; validation only described.
RSK-11	Mitigate	Define stock-adjustment transactions (wastage, return, expiry); reconcile system stock to physical count periodically; retain inventory transaction history.	ORG-01 (nurse/pharmacy custodian)	Before use with real patient data; monthly reconciliation	2/4 = 8 (Moderate)	H	Stock-out would interrupt treatment; behavior untested.
RSK-12	Mitigate	Obtain or define a retention schedule and disposal procedure for patient, notification, and report records, including cloud and archive copies.	ORG-01; ORG-02	Before real-data operation; annual review	2/3 = 6 (Moderate)	M	Policy gap with moderate impact; easily closed by document.
RSK-13	Mitigate	Document change approval with a second-person review and a handover/support arrangement naming the long-term custodian of deployment and maintenance.	ORG-01	Before capstone handover / real-data use	2/3 = 6 (Moderate)	M	Rests on an assumption to confirm with ORG-01.

No risk is marked Accept; acceptance of organization risk belongs to the system owner and City Health Office management.

3.1 Risk and Compliance Reconciliation

Check ID	Question	Result	Affected IDs	Correction / Limitation
REC-09-01	Does every High/Critical risk map to an audit objective, planned control test, or required treatment action?	Exception	RSK-01 to RSK-06, RSK-08, RSK-10, RSK-11	Each has a treatment action and audit priority (Section III), but Lab 10 control-test IDs are not yet assigned and Lab 7 objective IDs are not cited. Correction: assign test IDs and add OBJ links in Lab 10.
REC-09-02	Is every risk and requirement within the approved Lab 7 scope?	Exception	RSK-07, CMP-11; AST-08, AST-09; FLOW-04, FLOW-05	The Lab 7 workbook used for this draft lists SMS and reporting as Planned/out of scope and numbers modules MOD-01 to MOD-08, while Lab 8 lists SMS and reporting as active within MOD-01 to MOD-06. This draft follows Lab 8 IDs. Correction: confirm against the instructor-approved Lab 7 report v0.1; re-scope or remove RSK-07 and CMP-11 if those functions are excluded.
REC-09-03	Do all AST, ACC, INT, DEP, FLOW, and EVD IDs cited exist in the Lab 8 registers?	Pass	All cited IDs	Checked by comparing cited IDs against the Lab 8 registers.
REC-09-04	Do USR/ORG/DATA references match the Lab 8 registers?	Exception	USR-02; FLOW-02; DATA IDs	Lab 8 FLOW-02 cites USR-02/USR-03 for nurse or doctor, while the ACC register maps nurse = USR-03 and doctor = USR-04, and USR-02 is otherwise undefined. Lab 8 also has no DATA IDs; AST-04 to AST-06 and AST-09 stand in as data records. This draft cites ACC IDs and USR-03 to USR-06. Correction: fix in the master.
REC-09-05	Is every compliance status supported by evidence or marked Not Determined, with rationale?	Pass	CMP-01 to CMP-12	Ten rows are Not Determined, one Partial (CMP-05, design-level evidence only), one N/A with rationale.
REC-09-06	Does any residual score reduce likelihood or impact without verified safeguard evidence?	Pass	RSK-01 to RSK-13	No reductions applied; residual is Not Determined or equal to inherent.
REC-09-07	Does every material compliance/privacy gap link to a risk or required action?	Pass	CMP-01 to CMP-11; Section 2.2	Each row carries a related RSK ID and a gap/action.
REC-09-08	Are build, version, and evidence-cutoff statements consistent across Labs 7 to 9?	Exception	Cover table; Lab 7 v0.9 vs Lab 8 v1.0	Lab 7 workbook describes a v0.9 local/staging demo; Lab 8 describes v1.0 pilot deployment, and its cutoff cites a paper dated November 2026, later than the current date. Correction: confirm audited build, environment, and cutoff date; disclose any build change and refresh Lab 7/8 references.

IV. Lab 9 Completion Checklist

Check	Completion Requirement
[x]	Likelihood, impact, risk formula, risk bands, and residual-risk method are defined and consistently applied.
[x]	Every risk has a complete scenario, affected IDs, evidence/assumption, scores, owner, treatment, and priority.
[x]	Only applicable compliance and privacy requirements are included, with exact requirement, owner, evidence, and status (CMP-11 clause pending - see Gap/Action).
[x]	Not Applicable and Not Determined decisions contain clear rationales.
[x]	High/Critical risks and material compliance gaps link to planned control tests or required actions (with exception REC-09-01).
[ ]	Cross-review, AI validation, limitations, version control, and attestation are complete (pending member review and signatures).

V. Collaboration, AI Validation, and Instructor Review

V.1 Cross-Member Challenge Record

Draft entries: each reviewer must perform the challenge and record the actual resolution.

Review ID	Prepared By	Reviewed By	Item / Section	Challenge or Check	Resolution / Evidence
REV-09-01	Member 2 (Daclis)	Member 1 (Isidro)	CMP-01, CMP-05	Why do Sec. 13(f) and the IRR Sec. 28 measures apply to a pilot that Lab 7 authorizes only with demo data? Can CMP-05 be Partial when the evidence is a design description and an 8-respondent UAT?	[Reviewer to record.] Draft position: applicability stands because the system is designed to process patient health data; change CMP-05 to Not Determined if the evidence is judged insufficient.
REV-09-02	Member 1 (Isidro)	Member 2 (Daclis)	RSK-02, RSK-03 scores	Why is RSK-02 likelihood 3 rather than 4, and RSK-03 likelihood 2 rather than 3? What evidence supports each?	[Reviewer to record.] Draft position: scores follow the Section 1.1 descriptors; no log or configuration evidence exists to move either one.
REV-09-03	Member 1 (Isidro)	Member 3 (Tinaan)	RSK-06 evidence and affected IDs	Does RSK-06 really affect FLOW-06 and AST-05/AST-06 when AST-10 is partial/planned, and does INT-02 show all four record types are synchronized?	[Reviewer to record.] Draft position: INT-02 lists patient, schedule, inventory, and log records; narrow the IDs if the build shows otherwise.

V.2 Human-in-the-Loop AI Validation Log

AI ID	Tool / Purpose	Material Suggestion	Evidence / Criteria Checked	Decision	Correction / Rationale	Privacy Check
AI-09-01	Claude (Anthropic AI assistant) / first draft of risk scenarios, scores, and treatment plan	Proposed 13 risk scenarios with inherent scores and residual basis	Lab 8 registers (AST, ACC, INT, DEP, FLOW, EVD); Lab 9 scoring and residual-risk rules	[Pending: Accept / Revise / Reject per risk]	[Human judgment and final action]	Only Lab 7/8 text supplied; no credentials or patient data [group to confirm]
AI-09-02	Claude / suggested applicable privacy provisions	Proposed RA 10173 Secs. 11, 13(f), 14, 16, 20 and IRR Rule VI Secs. 25, 26, 28 and Rule IX	Official RA 10173 and IRR text (privacy.gov.ph); Compliance Analyst to verify wording and section numbers	[Pending]	[Human judgment and final action]	No sensitive data supplied [group to confirm]
AI-09-03	Claude / flagged differences between the Lab 7 workbook and Lab 8	Suggested using Lab 8 IDs as the reference basis and recording exceptions	Instructor-approved Lab 7 v0.1; Lab 8 registers	[Pending]	[Human judgment and final action]	No sensitive data supplied [group to confirm]

VI Group Attestation

We certify that the Lab 9 work reflects the identified capstone build and authorized evidence. We completed the assigned work and cross-review, protected confidential information, did not treat AI output as audit evidence, and disclosed material limitations.

Member	Printed Name	Signature	Date
Member 1	Edmar A. Isidro		
Member 2	Celso L. Daclis		
Member 3	Alvin T. Tinaan		

VII Instructor Review

Review Area	Status	Instructor Notes
Master-report continuity and prior feedback	[ ] Approved [ ] Revise	
Technical completeness and traceability	[ ] Approved [ ] Revise	
Evidence, limitations, collaboration, AI validation, and professional judgment	[ ] Approved [ ] Revise	

Instructor disposition and required revisions: Record the decision and detailed comments in the Instructor Notes column above or on the institution's grading sheet.

Drafting Notes for the Group (remove before submission)

1. Replace every bracketed placeholder: group number, preparation/submission dates, evidence cutoff, reviewer names, approval dates, and Closed By / date entries.
2. Resolve REC-09-02 and REC-09-08 first. The Lab 7 workbook (v0.9 demo, MOD-01 to MOD-08, SMS and reporting planned) does not match Lab 8 (v1.0 pilot, MOD-01 to MOD-06, SMS and reporting active). This draft follows Lab 8. If the approved Lab 7 report says otherwise, RSK-07, RSK-11, CMP-11 and the module references need revising.
3. The Lab 7 workbook's CRT IDs could not be matched to Lab 8, so CRT cross-references are marked [confirm]. Replace them with your approved CRT IDs.
4. Lab 8 numbers the build register Labs 9 to 14; the Lab 9 template uses Labs 7 to 12. This document uses the template numbering. Also replace the sample IDs left in the template (REC-11-01, REV-11-01, AI-11-01, FB-11-01); this draft uses 09 and keeps FB-08 IDs.
5. Verify every DPA/IRR citation against the official text before submission, especially the IRR rule numbers for breach notification (Rule IX) and organizational measures (Sec. 26). Do not state that the partner is legally compliant or noncompliant.
6. Each member must personally perform the cross-review (Section V.1), decide the AI-log entries (Section V.2), and sign the attestation. The REV and AI rows are drafts; edit them to match what actually happens.
7. Residual scores are Not Determined or equal to inherent because Lab 8 evidence is design-stage (capstone paper, UAT, survey). If you collect sanitized screenshots or configuration evidence, add EVD IDs and reassess.
8. Scores are a starting point for your own challenge. Nine of thirteen risks land in the High band because no safeguard is evidenced; check whether each likelihood and impact fits your descriptors.
9. Delete this page before submission.